

SENTRY

A 3-in-1 Static Security Configuration Linter

USER MANUAL

sshd | nginx | docker-compose

Course Mini Project: Custom Ethical Hacking Tool

Hood Security Department . NSSECU2 (S04) . Version 0.1.0

Static analysis only. This tool never connects to a live system.

1. Introduction

Sentry is a **static security config linter**. You point it at a config file and it tells you what's insecure: bad settings, unsafe defaults, and missing hardening, each with a severity, a short explanation, and a suggested fix. It works on three kinds of files: OpenSSH server configs (`sshd_config`), `nginx` configs, and `docker-compose` files.

Sentry is **static analysis only**. It reads the config text and never connects to, scans, probes, or tests any running system, service, or network. That makes it safe to run anywhere, including in a lab or classroom.

2. System Requirements

What you need	Details
Python	Version 3.10 or newer (we built and tested on 3.12)
Operating system	Linux, macOS, or Windows 11 / 10
Dependencies	<code>pyyaml>=6.0</code> and <code>rich>=13.0</code>
Internet	Only needed once, during install, to download the two packages
Disk / privileges	Tiny footprint; no administrator or root access needed

3. Installation

Unzip the project, then open a terminal in the folder that has `pyproject.toml`.

Option A: recommended (gives you the sentry command)

```
python -m venv .venv
# Linux / macOS:
source .venv/bin/activate
# Windows (PowerShell):
.venv\Scripts\Activate.ps1

pip install -e .
sentry --version
```

Option B: no install, just the dependencies

Install the two packages and run the tool as a Python module. With this option, write `python -m sentry` wherever this manual says `sentry`.

```
pip install -r requirements.txt
python -m sentry --version
```

Running on Windows 11 (PowerShell)

Windows works the same way, with a couple of notes that save you the usual headaches:

Add Python to PATH. Install Python 3.10 or newer from python.org and, on the first installer screen, tick “Add `python.exe` to PATH”. Then close and reopen PowerShell. This is what avoids the “sentry: command not found” and “python is not recognized” errors.

If activation is blocked. If PowerShell won't run `.venv\Scripts\Activate.ps1` and says scripts are disabled, allow it for your account, then activate again:

```
Set-ExecutionPolicy -Scope CurrentUser -ExecutionPolicy RemoteSigned
```

Or skip the virtual environment and just use Option B (`python -m sentry`), which doesn't need activation.

Paths and wildcards. Use backslashes in file paths. PowerShell won't expand a `samples\*.bad` wildcard, so list the files out:

```
sentry samples\sshd_config.bad
sentry samples\nginx.conf.bad samples\docker-compose.bad.yml --min-severity high
```

Checking the exit code. On Windows use `echo $LASTEXITCODE` (not `$?`). It prints 1 when there are high-severity findings and 0 when things are clean.

Colors. Run the tool in **Windows Terminal** (it's built into Windows 11) so the colors show up. The old `cmd.exe` may not render them. To open the HTML report from PowerShell, run `start report.html`.

4. Usage

Point Sentry at one or more files. It figures out the type from the filename, or you can set it with `--type`. The examples below use forward slashes; on Windows PowerShell, use backslashes (see section 3).

Common commands

```
# Scan a single file (type detected from the name)
sentry samples/sshd_config.bad

# Scan several files of different types at once
sentry samples/sshd_config.bad samples/nginx.conf.bad samples/docker-
compose.bad.yml

# Show only high-severity issues
sentry samples/nginx.conf.bad --min-severity high

# Make a shareable HTML report
sentry samples/nginx.conf.bad --format html --output report.html

# List every rule
sentry --list-rules
```

Options

Flag	What it does
<code>-t, --type</code>	Force a config type (sshd, nginx, docker-compose) instead of auto-detecting
<code>-f, --format</code>	Output format: console (default), json, or html
<code>-o, --output</code>	Write the report to a file instead of the screen
<code>--min-severity</code>	Hide findings below this severity (default: info)
<code>--fail-on</code>	Exit non-zero if any finding is at or above this severity (default: high)

Flag	What it does
<code>--list-rules</code>	Print every bundled rule and exit
<code>--version</code>	Print the version and exit

Exit codes

Sentry sets its exit code so it can run on its own in a CI pipeline:

Code	Meaning
0	No findings at or above the <code>--fail-on</code> threshold
1	Findings at or above the threshold
2	Usage or input error (missing file, unknown type, and so on)

5. Understanding the Results

Each finding has four parts: a **severity**, a **rule ID and title**, a **detail line** that says what was found and where, and a **fix**. Where it applies, it also points to a known benchmark (CIS, OWASP, or Mozilla).

Severity levels

Severity	What it means
HIGH	A serious weakness. Fix it before you deploy.
MEDIUM	A real weakness worth fixing.
LOW	A small hardening improvement or defense in depth.
INFO	Just a note, no direct risk.

One thing to know: a *missing* hardening setting counts as a finding on its own, because relying on an unsafe default is itself a risk.

6. Sample Run

Here's what a scan of the weak nginx sample looks like. It finds nine issues, groups them by severity, and shows the exact line, an explanation, and a fix for each one:

```
sentry samples/nginx.conf.bad
samples/nginx.conf.bad (nginx)
HIGH NGX-001 Deprecated TLS/SSL protocol versions enabled
line 10: contains disallowed value(s): TLSv1 , TLSv1. 1
fix: Use only modern protocols: 'ssl_protocols TLSv1.2 TLSv1.3;'
ref: Mozilla SSL Configuration Generator

HIGH NGX-003 Missing HTTP Strict Transport Security (HSTS) header
config: no matching directive sets 'Strict-Transport-Security'
fix: Add 'add_header Strict-Transport-Security "max-age=63072000; includeSubDomains"
always;'
ref: OWASP Secure Headers Project

HIGH NGX-008 Weak SSL cipher suite string
line 11: contains disallowed value(s): NULL, RC4, MD5, aNULL
fix: Restrict 'ssl_ciphers' to a modern list (e.g. Mozilla intermediate ).
ref: Mozilla SSL Configuration Generator

MEDIUM NGX-004 Missing X-Frame-Options / frame-ancestors protection
config: no matching directive sets 'X-Frame-Options'
fix: Add 'add_header X-Frame-Options "SAMEORIGIN" always;'
ref: OWASP Secure Headers Project

MEDIUM NGX-007 Directory autoindex is enabled
line 4: found 'on' , expected 'off'
fix: Set 'autoindex off;' (or remove the directive ).
ref: nginx autoindex module

LOW NGX-002 Server version banner is exposed
line 3: found 'on' , expected 'off'
fix: Add 'server_tokens off;'
ref: nginx core module docs

LOW NGX-005 Missing X-Content-Type-Options header
config: no matching directive sets 'X-Content-Type-Options'
fix: Add 'add_header X-Content-Type-Options "nosniff" always;'
ref: OWASP Secure Headers Project

LOW NGX-006 Server does not prefer its own cipher order
line 12: found 'off' , expected 'on'
fix: Add 'ssl_prefer_server_ciphers on;'
ref: Mozilla SSL Configuration Generator

LOW NGX-009 TLS session tickets are enabled
line 13: found 'on' , expected 'off'
fix: Set 'ssl_session_tickets off;'
ref: Mozilla server-side TLS guidance

Summary
9 finding(s): 3 HIGH 2 MEDIUM 4 LOW
```

Figure 1. Console output for `sentry samples/nginx.conf.bad`

You can also write the same scan to a self-contained HTML report with `--format html --output report.html`. It opens in any browser and is handy for sharing or dropping into a report.

7. How It Works

Sentry turns all three config formats into one common shape, then checks them with a single, generic rule engine. All the security knowledge lives as data in YAML rulesets, so adding a check doesn't mean changing the engine code.

Sentry: System Architecture

One data-driven engine, three configuration formats. Static analysis only, no network access.

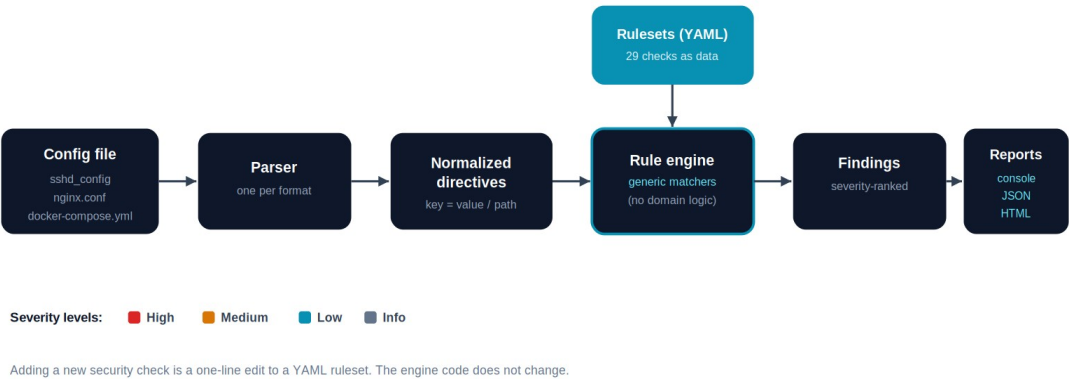


Figure 2. Processing pipeline

8. Troubleshooting

Problem	Fix
"sentry: command not found"	Use Option A (pip install -e .) to create the command, or just run python -m sentry.
"python is not recognized" (Windows)	Python isn't on PATH. Reinstall it and tick "Add python.exe to PATH", then reopen PowerShell.
"running scripts is disabled" (Windows)	Run: Set-ExecutionPolicy -Scope CurrentUser -ExecutionPolicy RemoteSigned, then activate again.
"cannot determine config type"	The filename wasn't recognized. Add --type sshd nginx docker-compose.
ModuleNotFoundError: rich / yaml	The dependencies aren't installed. Run pip install -r requirements.txt.
No color in the output	Normal when output is piped. On Windows, use Windows Terminal instead of cmd.exe.

9. Limitations

Sentry is a small, educational tool on purpose, and it isn't a replacement for a mature scanner. It ships with about 29 rules across three formats. It has no CVE or version-vulnerability checks. Its nginx parsing is directive-level rather than fully block-scoped. Its secret detection is pattern-based, so it can miss oddly named secrets. And findings for docker-compose files don't carry line numbers.

10. Ethical Reminder

This tool was developed for educational purposes only. It must only be used in authorized and controlled testing environments. Unauthorized testing against real systems, public websites, or third-party services is strictly prohibited.

Sentry only does static analysis of config text you give it. It doesn't connect to, scan, or test any live system. Make sure you have permission to review any file you run it against.